

UNIT-III

Conducting an IT Infrastructure Audit for Compliance

Q1. Explain the concept of Minimum Acceptable Level of Risk (MALR) and Baseline Security Definitions in IT auditing.

The **Minimum Acceptable Level of Risk (MALR)** and **Baseline Security Definitions** are fundamental elements in compliance-driven IT audits. They establish the security expectations, tolerance levels, and mandatory configurations required to maintain a secure and compliant IT environment.

1. Minimum Acceptable Level of Risk (MALR)

MALR represents the **maximum amount of residual risk** an organization is willing to tolerate after all controls have been applied.

It reflects the organization's:

- Business priorities
- Legal obligations
- Financial capacity
- Industry requirements
- Risk management strategy

MALR becomes a benchmark used by auditors to determine whether risk treatment and controls are sufficient.

2. Factors That Influence MALR

1. Regulatory Requirements

Laws set boundaries on acceptable risk.

Example: PCI DSS prohibits storing unencrypted cardholder data—risk cannot be accepted.

2. Business Impact

High-impact assets require lower acceptable risk.

Example: Financial systems cannot accept downtime risks.

3. Threat Landscape

Higher threats → lower tolerance.

4. Risk Appetite of Management

Leadership defines how much risk the organization is comfortable accepting.

5. Cost-Benefit Considerations

Controls must be cost-effective; otherwise, compensating controls are used.

3. Role of MALR in Compliance Audits

1. **Determines adequacy of implemented controls**
2. **Helps auditors evaluate whether risk is properly documented**
3. **Prevents unjustified acceptance of high-risk configurations**
4. **Supports governance and accountability**
5. **Ensures compliance with legal mandates**

If residual risk exceeds MALR → **non-compliance finding**.

4. Baseline Security Definitions

A security baseline is a **minimum required configuration** for systems, networks, and applications to ensure consistent security across the enterprise.

Characteristics of a Baseline

- Mandatory
 - Standardized
 - Documented
 - Auditable
 - Based on best practices (CIS Benchmarks, ISO standards)
-

5. Components of Security Baselines

1. System Configuration Standards

Examples:

- Disable guest accounts
- Enforce password complexity
- Enable audit logging

2. Network Baselines

Examples:

- Default deny firewall policies
- VLAN segmentation
- Disable unused ports

3. Application Baselines

Examples:

- Secure coding practices
- Input validation
- Authentication requirements

4. Patch and Update Baselines

Example: “All systems must apply critical patches within 72 hours.”

6. Importance of Baselines in IT Auditing

1. Provides measurable criteria for auditors

Auditors compare actual configurations against baseline standards.

2. Ensures uniformity across systems

Prevents inconsistent configurations that lead to vulnerabilities.

3. Supports compliance requirements

Standards like ISO 27001 mandate baseline documentation.

4. Reduces operational risk

Consistent hardening reduces attack surfaces.

7. Example (for exams)

Baseline:

“All Windows servers must have logging enabled.”

Auditor checks:

- Event Viewer settings
- Log retention policy
- SIEM integration

If the system deviates → **non-compliance issue**.

Conclusion

MALR defines how much risk is tolerable; baselines define minimum controls required. Together, they guide auditors in assessing compliance effectiveness and ensuring consistent security implementation across all IT domains.

Q2. Explain the Seven Domains of IT Infrastructure in the context of compliance auditing.

*(NOTE: This answer is different from Unit-I because now the focus is on **auditing activities** in each domain.)*

Compliance audits evaluate controls **domain-by-domain**, ensuring each part of the IT infrastructure meets policy and regulatory requirements. Auditors use the seven-domain model to systematically check risks and controls.

1. User Domain – Audit Perspective

Audit Focus:

- Acceptable Use Policy compliance

- Password policy enforcement
- MFA implementation
- User awareness training records
- User access review process

Example: Auditor verifies timely deactivation of terminated employee accounts.

2. Workstation Domain – Audit Perspective

Audit checks:

- OS hardening compliance
- Patch management records
- Antivirus and EDR status
- USB and peripheral restrictions
- Local admin privilege misuse

Example: Auditor checks if auto-updates are enabled.

3. LAN Domain – Audit Perspective

Audit evaluates:

- Switch security (STP, port security, MAC filtering)
- Network segmentation (VLAN compliance)
- DHCP, DNS security
- Internal access controls

Example: Auditor verifies VLAN tagging for sensitive departments.

4. LAN-to-WAN Domain – Audit Perspective

Audit checks:

- Firewall rule configurations

- IDS/IPS monitoring
- DMZ configuration
- NAT rules
- Proxy filtering

Example: Auditor confirms inbound firewall rules follow “deny-by-default”.

5. WAN Domain – Audit Perspective

Auditors check:

- WAN encryption (IPsec, MPLS security)
- Router baselines
- ISP SLA compliance
- Redundant WAN links

Example: Auditor verifies WAN failover functionality.

6. Remote Access Domain – Audit Perspective

Audit requirements:

- VPN configuration
- MFA for remote users
- Remote session logging
- Endpoint compliance checks
- BYOD/MDM policies

Example: Auditor confirms personal devices are restricted without MDM.

7. System/Application Domain – Audit Perspective

Auditors review:

- Server hardening baseline

- Patch/vulnerability management
- Database access control
- Application security controls
- Logging & backup compliance

Example: Auditor checks encryption at rest in databases.

Conclusion

The seven-domain model gives auditors a structured view of compliance requirements across the entire organization, ensuring thorough and consistent audits.

Q3. Write the structure of an IT Infrastructure Audit Report and explain its components.

The IT Infrastructure Audit Report is the **final deliverable** of an audit. It documents findings, evidence, compliance status, risks, and recommendations. It must be clear, accurate, and aligned with audit objectives.

1. Executive Summary

High-level summary for management:

- Purpose of audit
- Major findings
- Overall compliance status
- Critical issues requiring immediate attention

This section avoids technical jargon.

2. Audit Scope

Defines:

- Systems included

- Policies evaluated
- Locations covered
- Time period
- Compliance frameworks used

Example: “Audit covered ISO 27001 Annex A controls.”

3. Audit Objectives

Examples:

- Evaluate compliance with access control policies
- Verify monitoring and logging requirements
- Assess system hardening effectiveness

Objectives guide testing methodology.

4. Methodology

Explains how the audit was conducted:

- Interviews
- Document inspection
- Technical testing
- Sampling
- CAATs usage

Demonstrates transparency and repeatability.

5. Detailed Findings

Most important section. Includes:

- **Finding Description**

What control failed.

- **Criteria**

Which policy or regulation was violated.

- **Evidence**

Logs, screenshots, documents.

- **Impact**

Risk associated with the issue.

- **Root Cause**

Why the issue occurred.

- **Recommendation**

Action required to fix the issue.

- **Severity Rating**

Critical / High / Medium / Low.

6. Compliance Summary

Shows:

- Fully compliant areas
- Partially compliant areas
- Non-compliant areas
- Required corrective actions

Often displayed in tabular form for clarity.

7. Conclusion and Next Steps

Includes:

- Overall assessment
- Remediation roadmap
- Follow-up audit schedule

- Management responsibilities
-

8. Appendices

May include:

- Raw logs
 - Interview notes
 - Diagrams
 - Policies reviewed
 - Test scripts
-

Conclusion

The audit report communicates the compliance posture clearly and formally. Its structure ensures completeness, clarity, and actionable insight for management.

Q4. Explain compliance auditing activities within the User Domain and list common audit findings.

The User Domain includes all individuals who access organizational systems. Because users represent the largest attack surface, auditors examine whether controls reduce human-related risks and enforce compliance.

1. Audit Activities in the User Domain

1. Review of Access Control Policy Compliance

Auditors verify:

- Password complexity
- Password expiration
- MFA usage

- Login hour restrictions
 - Account lockout settings
-

2. User Account Management Audit

Checks:

- User provisioning process
- Approval workflow for new accounts
- Timely account deactivation
- Removal of orphan/dormant accounts
- Privilege level review

Example: Checking if employees who changed departments still have old privileges.

3. Review of Acceptable Use Policy (AUP)

Auditors examine:

- Whether AUP is documented
 - Whether users acknowledge AUP
 - Enforcement mechanisms
-

4. User Awareness and Training Audit

Auditors verify:

- Security training records
- Phishing awareness programs
- Policy compliance training

Regulations mandate periodic training.

5. Privileged Account Usage Audit

Auditors check:

- Number of admin users
- Privilege escalation approvals
- Logging of admin activities

Admin misuse is a high-risk issue.

6. Review of Logon and Authentication Logs

Auditors examine:

- Failed login attempts
 - Login from unusual locations
 - Concurrent login violations
-

2. Common Audit Findings in the User Domain

1. Weak Passwords

Users not following complexity rules.

2. Dormant or Orphan Accounts

Ex-employees still have active accounts.

3. Excessive Privileges

Users granted admin rights unnecessarily.

4. No MFA Enabled

A major compliance violation.

5. Lack of User Training

No documented training programs.

6. Non-Compliance with AUP

Users using systems for unauthorized purposes.

7. Inadequate Monitoring of User Behavior

Lack of periodic access reviews.

Conclusion

User Domain auditing focuses on human behavior, access controls, and policy enforcement. Common findings relate to weak authentication practices, excessive privileges, and poor training—all of which directly affect compliance status.

Perfect, Ridham.

Here are **UNIT-III — LONG ANSWERS (Q5 to Q8)**, each written in **1.5–2 page exam-ready format**, aligned with:

- ✓ NFSU MSc DFIS syllabus
 - ✓ Weiss & Solomon textbook
 - ✓ No case studies, only conceptual + examples
 - ✓ Structured, deep, and scoring
-

Q5. Explain compliance auditing activities within the Workstation Domain. What devices and components are commonly evaluated?

The **Workstation Domain** includes desktops, laptops, tablets, mobile devices, kiosks, and any endpoint interacting with the network. Because these devices are widely used and physically accessible, they pose a high security risk. Compliance audits ensure endpoints follow **security baselines, policies, and regulatory requirements**.

1. Devices and Components in the Workstation Domain

Auditors evaluate:

1. Operating Systems

- Windows
- Linux
- macOS

2. Installed Applications

- Productivity tools
- Browsers
- Security software

3. Endpoint Security Tools

- Antivirus and EDR
- Host firewalls
- Disk encryption

4. User Configurations

- Local accounts
- Group policy settings

5. Hardware Interfaces

- USB ports
- Wireless adapters
- Bluetooth connectivity

2. Audit Activities in the Workstation Domain

1. Workstation Hardening Audit

Auditors verify compliance with baseline configurations:

- Guest accounts disabled
- Password-protected screensavers
- Auto-lock policy
- OS hardening standard
- Least privilege for local users

2. Patch & Update Compliance

Workstations must:

- Install OS updates timely
- Apply application patches
- Auto-update security tools

Auditors may check:

- WSUS/SCCM reports
 - Patch cycle logs
 - Manual verification on sample endpoints
-

3. Antivirus/EDR Compliance

Auditors review:

- AV/EDR installation
- Real-time protection status
- Signature update frequency
- Tamper-protection settings

Example: Ensuring all endpoints have the latest signature files.

4. Device Encryption Audit

Compliance frameworks require:

- Full disk encryption
- Secure key storage
- Enforcement of BitLocker/FileVault/LUKS

Auditors confirm encryption reports match policy.

5. USB & Peripheral Access Controls

Audits check:

- USB blocking policies
- Logging of removable media usage
- Restrictions on unauthorized devices

High-risk violations occur when USB access is unrestricted.

6. Application Control Audit

Auditors examine:

- Unauthorized software installations
 - Use of whitelisting applications
 - Removal of outdated or vulnerable applications
-

7. Local Administrator Privilege Audit

Least privilege is required by nearly all standards.

Auditors check:

- Users with local admin rights
 - Approval process for admin elevation
 - Logs of privilege use
-

8. Logging and Monitoring Audit

Auditors verify:

- System logs enabled
 - Event logs retained for required duration
 - Forwarding to SIEM
-

3. Common Audit Findings

- Unpatched operating systems

- Disabled endpoint firewalls
 - Outdated antivirus signatures
 - Unauthorized software (games, torrents)
 - Excess administrator rights
 - No disk encryption
 - USB restrictions disabled
-

Conclusion

The Workstation Domain audit ensures all endpoints comply with security baselines, policies, and regulatory standards. Since workstations are frontline targets, strong compliance reduces organizational risk significantly.

Q6. Describe compliance requirements and auditing activities within the LAN Domain. How can organizations maximize CIA in the LAN environment?

The **LAN Domain** covers internal networks, switches, routers, communication channels, and shared network infrastructure. Because LAN is the backbone of internal communication, compliance audits ensure that policies enforce **confidentiality, integrity, and availability (CIA)**.

1. Compliance and Audit Requirements in LAN Domain

1. Network Segmentation Compliance

Auditors check:

- VLAN configurations
- Segregation of sensitive networks
- Access between VLANs

Example: Finance, HR, and server VLANs must be isolated.

2. Switch Security Audit

Auditors verify:

- Port security
- MAC address filtering
- STP protections (BPDU Guard, Root Guard)
- Disabled unused ports

Switch misconfiguration is a major cause of internal attacks.

3. LAN Access Control Compliance

Audits check:

- 802.1X NAC implementation
 - Authentication for wired/wireless clients
 - Guest network isolation
-

4. DHCP & DNS Audit

Auditors evaluate:

- DHCP logging
 - DNS filtering
 - Protection against rogue DHCP servers
-

5. LAN Traffic Monitoring

Audit verifies:

- NIDS/NIPS deployment
 - East-west traffic monitoring
 - Alerts for anomalous traffic
-

2. Maximizing CIA in the LAN Domain

A. Maximizing Confidentiality

Controls:

- VLAN segmentation
- Network access control (802.1X)
- Encrypted internal communication
- Port-level security

Example:

Disallow untagged access to server VLAN.

B. Maximizing Integrity

Controls:

- Secure routing and switching configurations
- Logging of switch configuration changes
- Use of checksum mechanisms
- ARP inspection
- DHCP snooping

These prevent spoofing, rogue devices, and data modification.

C. Maximizing Availability

Controls:

- Redundant switches and links
- Spanning Tree Protocol (STP)
- Load balancing
- QoS policies

- DoS protection

Example: RSTP prevents broadcast storms.

3. Common Audit Findings

- No VLAN segregation
 - STP protections not enabled
 - Open switch ports
 - Default switch passwords
 - No logs for switch configuration changes
-

Conclusion

The LAN audit focuses on segmentation, secure switch configurations, access control, and monitoring. Strengthening these areas directly enhances CIA and ensures regulatory compliance.

Q7. Explain auditing and compliance requirements within the LAN-to-WAN Domain. Include configuration validation and penetration testing roles.

The **LAN-to-WAN Domain** represents the boundary where the internal network connects to the external Internet. It includes firewalls, routers, DMZ components, IDS/IPS, and other perimeter security devices.

Compliance audits ensure proper protection, monitoring, and policy enforcement at this critical boundary.

1. Audit Scope in LAN-to-WAN Domain

Auditors evaluate:

- Firewall configurations
- Router ACLs
- Proxy filtering

- NAT rules
- IPS/IDS settings
- DMZ segregation
- Internet access controls

Mistakes in this domain expose the organization to external attacks.

2. Key Audit Activities

1. Firewall Rule Audit

Auditors inspect:

- Allow/deny rules
- Default deny policy
- Open ports and services
- Rule justification and approvals
- Shadowed or redundant rules

Example: Only ports 80/443 should be exposed for a web server.

2. Router Configuration Audit

Checks include:

- ACL enforcement
 - Routing protocol security (OSPF authentication)
 - Disabled unused services
 - Encryption on WAN links
-

3. DMZ Configuration Audit

Auditors review:

- Segregation between LAN–DMZ–Internet
 - Reverse proxies
 - Application gateways
 - Server hardening in the DMZ
-

4. IDS/IPS Audit

Auditors check:

- Alert generation
 - Signature update status
 - Blocking mode vs alert-only mode
 - False positive/negative analysis
-

5. Proxy & Web Filtering Audit

Verifies:

- URL filtering
 - Malware detection
 - HTTPS inspection
 - Logging
-

3. Role of Configuration Validation

Auditors validate configuration through:

- Firewall rule reviews
- Router running-config checks
- Hash comparison of configurations
- Comparing live configuration with baseline

Example: Auditors verify firewall denies all inbound traffic except approved services.

4. Role of Penetration Testing

Pen-testing supplements audits by identifying:

- Misconfigured firewall rules
- Exposed ports/services
- DMZ weaknesses
- Router ACL bypasses
- DNS misconfigurations

Penetration tests confirm whether controls **actually work** as intended.

5. Common Audit Findings

- Open ports not documented
 - Outdated IDS signatures
 - Weak router ACLs
 - DMZ servers directly accessible from LAN
 - Incorrect NAT rules
 - Firewall admin access from Internet
-

Conclusion

The LAN-to-WAN audit ensures perimeter defenses are strong, documented, tested, and compliant. Penetration testing validates real-world security and helps auditors ensure controls function effectively.

Q8. Explain compliance auditing activities within the WAN Domain. What components are commonly evaluated?

The **WAN Domain** includes remote office connectivity, leased lines, MPLS links, ISP connections, VPN concentrators, and cloud network paths.

Compliance audits ensure connectivity is secure, monitored, and aligned with organizational policies.

1. Components Evaluated in WAN Domain

- Routers
 - WAN optimization devices
 - MPLS/leased line connections
 - VPN concentrators
 - SD-WAN controllers
 - ISP connections
 - WAN redundancy equipment
-

2. Audit Activities in the WAN Domain

1. WAN Encryption Audit

Auditors verify:

- IPsec encryption on WAN tunnels
- Key exchange security
- Certificate management
- Strong encryption algorithms

Compliance requires protection of data in transit.

2. Router Security Audit

Auditors check:

- ACL enforcement
- Password strength

- SSH instead of Telnet
 - Routing protocol authentication
-

3. WAN Redundancy & Failover Audit

Evaluates:

- Backup links
- Automatic failover
- Heartbeat testing
- Load balancing

Ensures availability compliance.

4. ISP Contract Compliance

Auditors verify:

- SLA agreements (uptime, latency)
- Response time guarantees
- Security commitments

Documented ISP SLAs are required in many audits.

5. WAN Monitoring Audit

Auditors evaluate:

- Bandwidth monitoring
 - Latency measurement
 - Traffic anomalies
 - Link utilization reports
-

3. Maximizing CIA in WAN

Confidentiality

- IPsec VPN
- Strong authentication
- Tunnel integrity checks

Integrity

- Routing protocol security
- Configuration integrity (checksums/hashes)

Availability

- MPLS + backup Internet
- Failover routing
- ISP redundancy

4. Common Audit Findings

- WAN tunnels without encryption
- Weak router passwords
- Outdated firmware
- WAN failover not tested
- No SLA documentation
- Excessive WAN bandwidth usage without monitoring

Conclusion

WAN Domain audits ensure secure, reliable, and compliant wide-area connectivity. Evaluating routers, tunnels, ISPs, and redundancy mechanisms strengthens CIA and organizational resilience.

Q9. Explain compliance auditing activities within the Remote Access Domain. What devices and components are commonly evaluated?

The **Remote Access Domain** includes all technologies, protocols, authentication mechanisms, and devices that allow users to connect from outside the corporate network. Because remote access significantly expands the attack surface, compliance audits focus on ensuring secure, authenticated, logged, and policy-driven access.

1. Components Evaluated in Remote Access Domain

Auditors typically review:

1. VPN Servers and Concentrators

- SSL VPN
- IPsec VPN
- Remote access gateways

2. Authentication Systems

- MFA servers
- RADIUS/TACACS+
- Identity providers (AD, LDAP)

3. Endpoints

- Laptops
- BYOD devices
- Mobile devices

4. Remote Desktop Services

- RDP
- VDI (Virtual Desktop Infrastructure)

5. Network Access Control (NAC) Tools

- Posture assessment tools
- Compliance check tools

2. Audit Activities in Remote Access Domain

1. Authentication & Authorization Audit

Auditors verify:

- MFA implementation
- Password complexity compliance
- Remote access approval workflow
- Least privilege enforcement

Example:

MFA must be enabled for all VPN logins.

2. Review of VPN Configuration

Auditors examine:

- Encryption strength (AES-256 recommended)
- Tunnel integrity
- Split tunneling policy
- VPN session timeout
- NAT traversal settings

Split tunneling is often prohibited in compliance frameworks.

3. Endpoint Security Compliance

Auditors check:

- Antivirus/EDR installation
- OS updates
- Disk encryption

- MDM enrollment for BYOD devices
- Firewall status

Non-compliant devices must be blocked via NAC.

4. Remote Access Logging and Monitoring

Auditors verify:

- VPN connection logs
- Failed login attempts
- Source IP logs
- Session duration logs
- Admin remote access logs

These logs support forensic needs and compliance reporting.

5. Remote Desktop and VDI Audit

Checks include:

- Secure RDP configuration
 - Account lockout policies
 - Screen lock settings
 - Clipboard/file-sharing restrictions
-

6. Access Control Lists (ACLs) for Remote Users

Auditors verify:

- Remote users can only access permitted resources
 - No internal admin access
 - No cross-VPN traffic
-

3. Common Audit Findings

- No MFA enabled
 - Weak VPN encryption
 - Split tunneling allowed
 - Outdated endpoint software
 - Missing remote session logs
 - Users accessing unauthorized networks
 - BYOD devices not enrolled in MDM
-

Conclusion

Remote Access Domain auditing ensures that external connections into the internal network are **secured, authenticated, encrypted, logged, and policy-compliant**. It reduces exposure to cyberattacks and ensures regulatory adherence.

Q10. Explain compliance auditing activities within the Application Domain. Include vulnerability management and configuration checks.

The **Application Domain** includes all enterprise applications, web services, APIs, databases, middleware, and supporting components. Compliance audits ensure applications meet required security, privacy, and operational standards.

1. Audit Scope in Application Domain

Auditors examine:

- Web applications
- Internal business apps
- Database systems
- Application servers
- Middleware (Tomcat, WebLogic, IIS)

- APIs and microservices
-

2. Audit Activities

1. Application Security Configuration Audit

Auditors check:

- Authentication mechanisms
- Session management
- Input validation
- Secure cookie flags
- Error handling and logging

Example:

Verify session timeout policy is enforced.

2. Access Control Audit

Auditors verify:

- RBAC implementation
 - Segregation of duties
 - Privileged user restrictions
 - API key management
-

3. Vulnerability Management Audit

Applications often contain vulnerabilities like:

- XSS
- SQL Injection
- CSRF

- Directory traversal

Auditors check:

- Vulnerability scan reports
 - Pen-test findings
 - Patch and fix verification
 - Secure coding compliance
-

4. Patch & Update Compliance

Auditors verify:

- Timely application patching
 - Third-party library updates
 - Middleware patch cycles
 - Zero-day response processes
-

5. Database Security Audit

Includes:

- Authentication methods
 - Encryption (TDE)
 - Backup and recovery controls
 - SQL injection protection
 - Audit log configuration
-

6. Application Logging and Monitoring

Auditors ensure:

- Application logs are enabled
- Sensitive data is masked in logs

- Failed login attempts are logged
 - Logs are forwarded to SIEM
-

7. API Security Audit

Checks include:

- API authentication (OAuth, tokens)
 - Rate limiting
 - Input validation
 - TLS enforcement
-

3. Common Audit Findings

- Hardcoded passwords
 - Missing patches
 - Weak session management
 - API keys exposed
 - SQL injection vulnerabilities
 - Unencrypted sensitive fields
-

Conclusion

Application Domain auditing ensures applications are securely configured, maintained, monitored, and protected from vulnerabilities. It plays a crucial role in compliance with cybersecurity standards.

Q11. Explain Application Patch Management and its importance in compliance auditing.

Patch management ensures that applications remain secure and compliant by addressing vulnerabilities, improving stability, and maintaining functionality.

1. Definition of Patch Management

Patch management includes:

- Identifying patches
- Testing patches
- Deploying patches
- Verifying patch implementation
- Documenting patch activities

Patches may include security fixes, feature updates, or hotfixes.

2. Patch Management Lifecycle

1. Patch Identification

Sources include:

- Vendor alerts
 - Security bulletins (CVE databases)
 - Vulnerability scans
-

2. Patch Prioritization

Based on:

- Severity (critical, high, medium)
- Exploit availability
- Regulatory deadlines

Example: Critical vulnerabilities must be patched within 72 hours.

3. Patch Testing

Patches are tested in:

- Staging environments
- Test servers
- Sandboxed environments

Testing ensures compatibility.

4. Patch Deployment

Methods:

- Automated tools (WSUS, SCCM, Ansible)
 - Manual deployment
 - Scheduled maintenance windows
-

5. Patch Verification and Reporting

Auditors check:

- Patch logs
 - Scan results
 - Ticketing system updates
-

3. Role in Compliance Auditing

Compliance standards require timely patching:

- ISO 27001 → A.12.6 “Management of technical vulnerabilities.”
- PCI DSS → 30-day patch cycle.
- SOC → Continuous vulnerability management.

Auditors verify:

- Patch policy existence
- Patch timelines

- Patch testing records
- Evidence of deployed updates

Failure to patch is a major cause of breaches.

4. Common Audit Findings

- Missing critical patches
 - No patch testing
 - Outdated application versions
 - Inconsistent patch cycles
 - No patch deployment documentation
-

Conclusion

Patch management is essential for closing vulnerabilities, ensuring application stability, and achieving compliance. Auditors view patch compliance as a top-tier requirement.

Q12. Explain Application Vulnerability Management and its relevance to compliance.

Vulnerability management ensures the identification, assessment, prioritization, and remediation of application weaknesses. It is essential for compliance because most regulations require continuous vulnerability reduction.

1. Stages of Vulnerability Management

1. Identification

Sources include:

- Automated scanners (Nessus, Qualys)
- Code reviews
- Penetration testing

- Security advisories
-

2. Classification

Vulnerabilities are categorized by:

- Severity (Critical → Low)
 - Impact (CIA impact)
 - Exploitability
 - Affected systems
-

3. Prioritization

Criteria include:

- CVSS score
 - Exposure
 - Business criticality
 - Regulatory requirements
-

4. Remediation

Fix strategies:

- Patch deployment
 - Secure coding updates
 - Configuration changes
 - Workarounds
 - Compensating controls
-

5. Verification

Auditors look for:

- Rescanning reports
 - Remediation evidence
 - Documentation
-

2. Importance of Vulnerability Management in Compliance

1. Required by Regulations

- ISO 27001
- PCI DSS
- HIPAA
- SOC
- GDPR

All require vulnerability identification and remediation.

2. Reduces Risk Exposure

Prevents:

- Data breaches
 - Ransomware attacks
 - System compromise
-

3. Provides Audit Evidence

Documentation includes:

- Scan results
 - Remediation tickets
 - Vulnerability reports
-

4. Supports Secure SDLC

Applications become secure-by-design.

3. Common Audit Findings

- Unpatched vulnerabilities
 - No vulnerability scanning schedule
 - Missing remediation evidence
 - High-risk findings unfixed
-

Conclusion

Vulnerability management ensures applications remain secure, resilient, and compliant. It is a foundational requirement in any cybersecurity and compliance framework.
